

ASHAKids | Auditoría del núcleo integrado

AUDIT-2026-10-09-07 — aceptación HTTP, PDF y mensajes en clon limpio

Fecha: 2026-10-09, verificaciones durante 04:35–05:05 America/Lima. Responsable: desarrollo asistido en el clon de Piero. Entrega académica: hoy18:00 Lima.

Repositorio: <https://github.com/sromansilva/ashakids-platform> . Rama: dev. Aplicación reproducida: e456294cd7d13aea41dc5d00940b84aa782acbad, V10_Integracion_Mensajeria/PR106 integrado. Guiones y cuatro pruebas nuevos: 8578ca9cde56bac2ec04389a58ae282cc3fdc8e3, V11_Verificacion_Nucleo_Reportes_Mensajes. Documentación de este corte se prepara después en V12_Auditoria_Nucleo_Integrado; no confundir SHA de aplicación con SHA del guion.

Árbol: código de verificación comprometido, documentación en preparación. Un clon nuevo de GitHub instaló dependencias desde cero; aplicación sin modificaciones y git status limpio, con entorno/dependencias ignorados. Misma persona/agente y ordenador, no reproducción independiente de un compañero.

01. Dictamen ejecutivo

El núcleo y los dos módulos seleccionados de F5-01 funcionan juntos por HTTP con PostgreSQL real. Dos bases nuevas pasaron el mismo recorrido de92 respuestas verificadas. Reporte y mensajes sobreviven a logout/login; PDF contiene los campos guardados. Se comprobó rechazo de escritura tras finalizar tratamiento/archivar chat en SQL de esta fixture nueva. La aceptación visual y de equipo sigue abierta; no se declara toda fase5 cerrada ni despliegue estable.

Indicador	Resultado nuevo	Alcance
Backend del clon	115 correctas,25 omitidas,19 advertencias	Suite completa sobre BD local de regresión separada
Backend final + guarda	119 correctas,25 omitidas,19 advertencias	Cuatro casos nuevos; mismo código app, guion nuevo
Frontend / rutas	232 componentes +25 rutas correctas	Clon vacío, tipos/estructura/build correctos; jsdom
Recorrido HTTP	92 por corrida, repetido en dos BD nuevas	SQL y HTTP reales; no sumar como184 casos distintos
Restauración / guarda	6 respuestas + comprobaciones SQL	Demo original recuperada; instancia divergente rechazada

02. Arquitectura, estructura y reproducción

Se conserva React/TypeScript -> API HTTP/cookie -> FastAPI -> servicios -> SQLAlchemy/asyncpg -> PostgreSQL. El corte no añade funcionalidades de producción ni decisiones de arquitectura nuevas: amplía el guion de aceptación, la inspección de modelos y la prueba del destino real. ADR0006/0007 permanecen vigentes.

Instalación real nueva en tmp/acceptance07/clone: Python3.13.7, venv vacío, pip requirements-dev.txt y npm ci. Node26.9.0/npm11.19.1; FastAPI0.143.0, SQLAlchemy2.1.4, asyncpg0.32.0, pytest9.1.1, httpx0.28.1, ReportLab4.5.1, pypdf6.19.0 y tzdata2026.5. Frontend según lockfile; índice292.83kB/gzip92.55kB, no benchmark.

PostgreSQL17.6 y su cluster ya existían: no se reinstaló el servidor ni se probó otro sistema operativo. Puerto6544. BD nuevas accept07 y accept07_repeat para recorridos, regress07 para pytest; todas con prefijo ashakids_test_. Runtime no superusuario, sin CREATEDB/CREATEROLE, con BYPASSRLS como la réplica anterior. Propietario separado prepara/restaura; FastAPI usa runtime.

Componente físico	Evidencia nueva local
Tablas / columnas	26 tablas,178 columnas; metadatos en transacción READ ONLY
Restricciones / índices	92 restricciones,71 índices restaurados
Modelos ORM	19 tablas modeladas;0 diferencias de columnas, incluida mensajería
Clínica y comunicación	Un paciente, tratamiento, cita, sesión, reporte, conversación y2 mensajes nuevos por corrida

SQL fuente del corte02: solo estructura, sin filas reales. Se hizo portable únicamente CREATE SCHEMA public -> IF NOT EXISTS, porque public ya existe en una BD nueva. No se volvió a comparar Supabase ni se cambió su esquema. La equivalencia compartida02 es evidencia histórica; las comprobaciones locales anteriores son nuevas.

03. APIs funcionando: identidad y pacientes

Cinco identidades iniciales sintéticas cubren ADMIN, dos familias y dos terapeutas. ADMIN crea otra cuenta familiar mediante la API; suspenderla revoca la sesión, bloquea login y reactivarla permite acceder otra vez. No se usan personas ni datos reales.

Método y ruta / caso	Estado	Resultado
POST /auth/login	200/401	Sesiones válidas; contraseña incorrecta/cuenta inactiva rechazadas
GET /usuarios	200/403	Solo administración consulta cuentas
POST /usuarios; PATCH /usuarios/{id}	201/200	Alta, baja lógica y reactivación de cuenta sintética
GET /auth/me tras suspensión	401	Cookie previa revocada por el servidor
POST /pacientes	201	Paciente ligado al tutor autenticado
POST /tratamientos	201/403	ADMIN asigna; familia no concede esa relación
GET paciente/cita/sesión/reporte ajenos	404	Otra familia y profesional no asignado sin acceso

Antes de la primera escritura clínica, el guion final busca en la BD local declarada el hash de la sesión recién emitida por la API. Debe existir, estar activa y no vencida. No registra cookie/token/hash en la evidencia. Esto comprueba la instancia real, además de validar las variables de entorno. Login/logout sí produce eventos de sesión, incluso antes de esa guarda.

Prueba controlada con la API original y otra BD vacía: sesión encontrada en la BD correcta, rechazada en la divergente;0 mutaciones clínicas enviadas. Cuatro unidades cubren cookie ausente/múltiple, sesión no encontrada y consulta válida. No reemplaza guardas loopback8001/BD local ni autoriza un destino compartido.

04. APIs funcionando: citas, reportes y mensajes

Recorrido / regla	Resultado real
Familia reserva; terapeuta confirma	201/200; reserva superpuesta409, familia no confirma403
Profesional crea/inicia sesión	201; duplicada409; inicio antes del horario409
Reporte y cierre	Guardado200; familia no edita403; FINALIZADA/ASISTIO y cita COMPLETADA
PDF por tres roles autorizados	200, MIME/firma PDF/no-store/nosniff; campos JSON iguales
PDF/recursos ajenos	404; permisos clínicos distintos del chat administrativo403
Chat de pareja asignada	Aperturas simultáneas200 con mismo ID; dos mensajes201
Historial / volver a iniciar sesión	Dos mensajes paginados sin repetición; JSON idéntico tras relogin
Origin ajeno / texto inválido / emisor extra	403/422/422; sin escrituras nuevas
Tratamiento finalizado / chat archivado	Envío403/409; historial conserva lectura a participantes

El tiempo de la cita recién creada se ajusta por SQL únicamente en esa fixture: primero demuestra el rechazo por futuro, después permite iniciar. También se finaliza/reactiva únicamente su tratamiento y se archiva únicamente su chat para los dos últimos casos. No cambió el reloj del ordenador ni se añadieron endpoints de archivado/edición de estado de tratamiento.

Corridas: http-delivery-first.json y http-delivery-journey.json, cada una92 respuestas correctas. La final incorpora prueba de sesión/BD antes de clínica. Cada BD conserva6 cuentas,1 paciente/cita/sesión/reporte/chat y2 mensajes; sin reset entre evidencias. Se guarda PDF sintético de ambas corridas; la muestra final fue cotejada y renderizada.

Demo compat17: conteos antes/después iguales (5 usuarios,2 pacientes,2 citas,1 sesión/reporte/chat y14 mensajes). API8001 se restauró y6 respuestas verifican salud, readiness, login, reporte02, historial14 y logout. No es snapshot de cada byte; las sesiones de autenticación sí cambiaron.

05. Pendientes y capacidades no certificadas

Pendiente	Estado / acción
UI real de mensajes y recaptura PDF	Navegador todavía deniega5174; completar desktop/móvil/teclado cuando permita
Reproducción por compañero	Clon limpio probado por mismo agente; otro integrante debe ejecutar su guion
Impacto de incidencia01	Guarda reforzada y regresión probada; logs/baseline históricos del equipo necesarios
Estabilidad de entrega / hosting	Aceptación API positiva; no cierre integral ni elección/despliegue de host
Recursos / extensiones6	Diferidos/por confirmar; sin ampliar alcance mientras falta aceptación
Mundo ASHA	Etapas MA independiente; no juegos completos certificados
Pagos	Excluidos; sin nuevas tareas de simulación o cobro

Navegador: inventario leído; un intento de seleccionar la pestaña5174 fue rechazado por preferencia guardada, tras la respuesta del usuario indicando que habilitó acceso. No se utilizaron otro origen, puerto, Chrome, CDP o automatización indirecta para eludirlo. No hay capturas nuevas ni interacción UI certificada en este corte.

Cerrar/reabrir servicios no elimina un permiso guardado del navegador. Se reinició solo la API de pruebas8001 para cambiar de fixture y restaurarla; no se cerraron todos los puertos. Guía oficial consultada: <https://help.openai.com/en/articles/20001277-using-the-built-in-browser-in-the-chatgpt-desktop-app> . Sitios permitidos/bloqueados se gestionan en ajustes de la aplicación; no se alteró esa preferencia desde código.

Los232 componentes se ejecutan en jsdom con HTTP simulado. Las92 respuestas sí usan red local y PostgreSQL real. Readiness solo prueba conexión, tipos/build solo comprueban sus respectivas condiciones. Ninguno sustituye comprobar cada pantalla, dispositivo o despliegue.

06. Seguridad, incidentes y límites

Prioridad	Hallazgo / evidencia	Acción
Alta	Incidencia01 alcanzó API habitual, según registros históricos sin hora por petición	No se atribuye conteo exacto ni restauración; contrastar logs y cuentas del equipo
Alta	Variables de cliente no prueban la BD del servidor	Nueva guarda verifica sesión emitida en BD, antes de mutación clínica; probada negativa/positiva
Media	UI y reproducción independiente pendientes	Mantener F5 abierta y hosting sin selección hasta aceptación comprobada
Media	Envío sin clave idempotente y pareja sin UNIQUE	Límites de ADR0007; no declarar garantía de escritores externos/respuesta perdida
Media	Runtime local BYPASSRLS y sin SSL	Solo fixture loopback; no certifica permisos ni conexión de producción

Incidencia01: esta revisión es documental y de contención nueva local. El primer informe conserva registros de altas/bajas de cuentas de prueba e IDs44/45; no permite reconstruir todo el impacto porque faltan timestamps/baseline. No se accedió a Supabase, se restauraron cuentas ni se ejecutó una limpieza compartida. Mantener revisión de impacto abierta.

Fallos de preparación registrados: dump creó public ya existente, deteniendo restore; intento de grant/seed posterior falló por tabla roles ausente. Se hizo copia portable y restauración completa correcta. Primera prueba Node falló spawn EPERM del sandbox y pasó al repetirla con autorización. La primera consulta de procesos fue denegada; API nueva no pudo ocupar8001. Se identificó/paró solo el proceso de prueba con autorización y arrancó correctamente.

Las fuentes/evidencias/PDF se revisan contra secretos configurados y patrón JWT, sin imprimir valores. Esa revisión dirigida no es detección exhaustiva ni pentest. No hubo nuevas dependencias funcionales, cambios de tablas compartidas o manejo de pacientes reales.

07. Evidencia, pruebas y rúbrica

Comando / ejecución	Resultado	Archivo en evidencia07
pip requirements-dev.txt / npm ci del clon	Instalación correcta	backend-install.txt / frontend-install.txt
pytest completo del clon	115 correctas,25 skip,19 avisos	backend-tests.xml / .txt
pytest completo final con guarda	119 correctas,25 skip,19 avisos	backend-tests-final.xml / .txt
npm test:components / test:routing	232 /25 correctas	frontend-tests.xml / routing-tests.txt
npm typecheck / check:frontend / build	Correctos;318 fuentes/máximo495	Logs respectivos
verify_delivery_journey	92 correctas, dos corridas	http-delivery-first.json / http-delivery-journey.json
inspect_schema_compatibility --target local	READ ONLY,0 diferencias	schema-local.json

Omisiones:20 de suites HTTP heredadas deshabilitadas y5 de integración compartida sin autorización. No se habilitaron para sumar cifras. Advertencias:1 de deprecación de Starlette/TestClient y18 de cookies por petición. La suite de integración SQL nueva usa regress07 con fixtures que hacen TRUNCATE; jamás compat17 o Supabase.

npm ci:180 paquetes instalados,181 auditados,0 vulnerabilidades reportadas por npm en esa corrida; aviso de dependencia obsoleta y dos install scripts sin allowScripts. Build/pruebas funcionaron; no se cambió la política de scripts ni se presenta ese contador como auditoría de seguridad completa. No detector UI nuevo porque no se modificó UI ni pudo inspeccionarse visualmente.

Rúbrica visible: arquitectura/capas y guion respaldan backend; metadatos/PK-FK y escrituras/lecturas reales respaldan BD; permisos, revocación, entrada y concurrencia de apertura respaldan seguridad/validación. Los tiempos HTTP observados son diagnósticos de esta máquina, no carga/SLA. Graphify AST local y check actual; mapa ignorado.

08. Cierre y continuidad

Aceptación de núcleo+PDF+mensajes verificada por API/SQL y repetida en dos bases locales nuevas; instalación del clon limpio comprobada. Pendientes: revisión visual del producto, otro integrante y revisión de impacto histórico. No se declara F5 íntegra, producción, operación clínica o un host gratuito elegido.

Guion completo: docs/acceptance/CORE_PDF_MESSAGES.md. Explica instalación, prefijos/roles locales, restauración portable, separación de BD de regresión y recorrido manual. No repetir fixtures sobre la demo. Estado al terminar pruebas: API8001 vuelve a compat17, frontend5174 conservado; bases nuevas/evidencia disponibles.

1. Retirar el bloqueo guardado del origen5174 en ajustes de Codex y aceptar UI real desktop/móvil: tres roles, PDF guardado y mensajes entre dos cuentas; registrar evidencia propia y fallos. No solicitar acceso por otro origen para esquivar una negativa.
2. Otro integrante actualiza dev y reproduce el guion en su entorno. Verificar incidencia01 con logs/baseline del equipo; contención del guion no demuestra reparación histórica. Reunir las evidencias de arquitectura, BD y seguridad para entregar hoy antes de 18:00 Lima.
3. Cerrar F5 solo después de aceptación del alcance seleccionado. Recursos y Mundo ASHA siguen diferidos/etapa propia. Extensiones6 por confirmar; comparación de hosting gratuito después de demostrar estabilidad, con documentación vigente en esa fecha.

Publicación prevista de este corte: V11 código de verificación ya comprometido; V12_Auditoria_Nucleo_Integrado documentación/evidencia; PR hacia dev y V13_Integracion_Aceptacion_Nucleo. Al generar el informe no se afirma un merge futuro como concluido: consultar PR/Git para SHA efectivo. Actualizar contexto/plan/relevo e índice junto a la entrega; conservar auditorías anteriores.

Repositorio académico: <https://github.com/sromansilva/ashakids-platform> . Evidencia07 incluye JSON/JUnit, logs, muestra PDF, QA y manifest sanitizados; el siguiente equipo debe conservar límites y no atribuir cifras de 02/05/06 a verificaciones nuevas.